

Pre-Windows 2000 Compatible Access Group

 michaelwaterman.nl/2024/02/27/unmasking-the-legacy-how-the-pre-windows-2000-compatible-access-group-haunts-powerbi-users-today

Michael Waterman

February 27, 2024



Today I've learned,

That even software and designs from quarter of a century ago still influence the modern Cloud enabled world. In this specific case I'm talking about the PowerBI gateway and how it operates in an on-prem Active Directory environment. Allow me to explain...

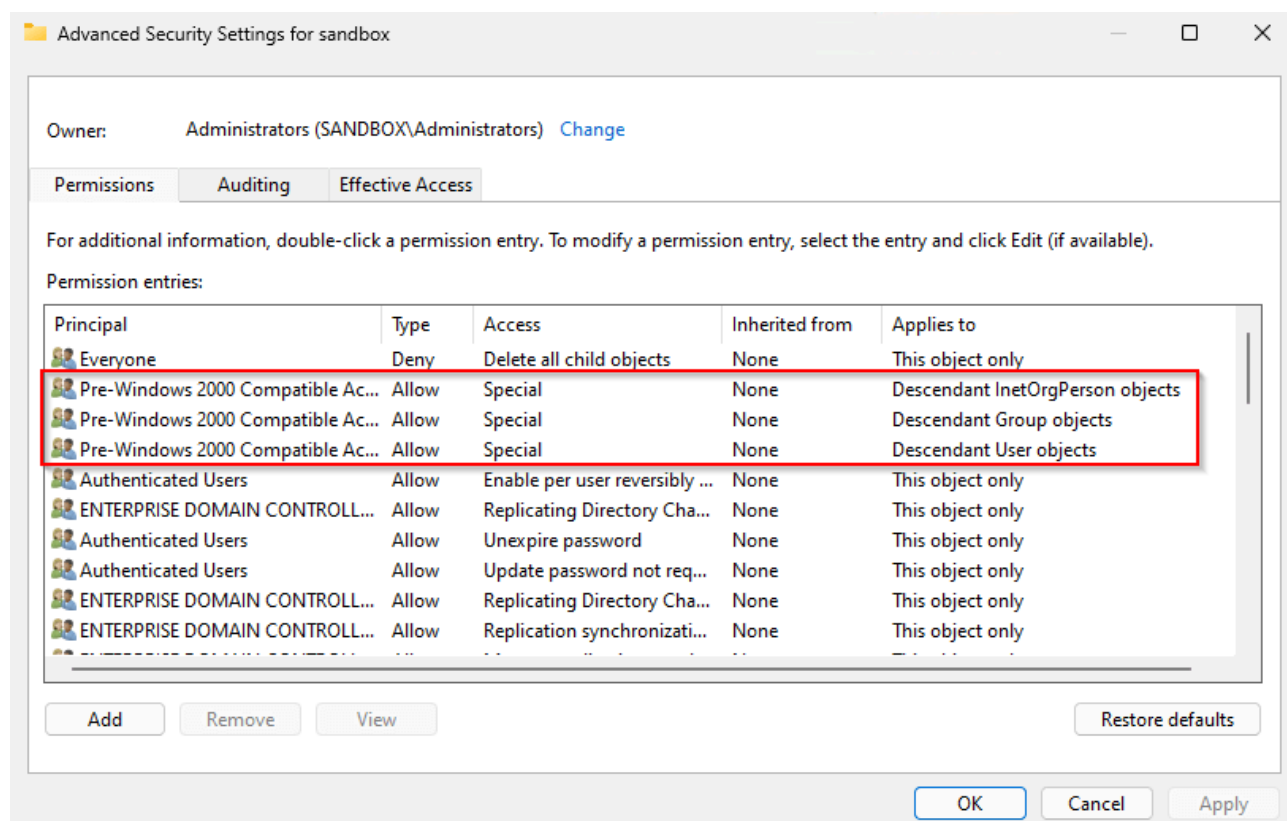
As part of my day to day job I assist customers in hardening their Active Directory (AD) infrastructure. Why you ask? Well because in 95% of the time on-prem AD is the leading identity source and since it's software that's been developed over 25 years ago, it was a different world and AD needs to be tweaked to combat modern threats that target this infrastructure.

One of the most fantastic tools to do a fast but thorough security investigation is [PingCastle](#), it does the work in 1 minute that would take me 3 days of manual labor. At most customers this leads to month's of work cleaning up, creating procedures (it's not all technology kids), and adjusting settings. One of the most common items that PingCastle finds is the presence of the "Authenticated Users" pseudo group in the "Pre-Windows 2000 Compatible Access" group. Let me explain briefly what this group actually does.

If you're under 35 you probably never had the pleasure of migrating from Windows NT4 to Windows NT5, aka Windows 2000. Among the many enhancements brought by this Operating System was the introduction of Active Directory which, compared to NT4 domains brought many new features like group policies, hierarchical organizational units, Kerberos Authentication and the ability to introduce the principle of least privilege, only use what you need and nothing more.

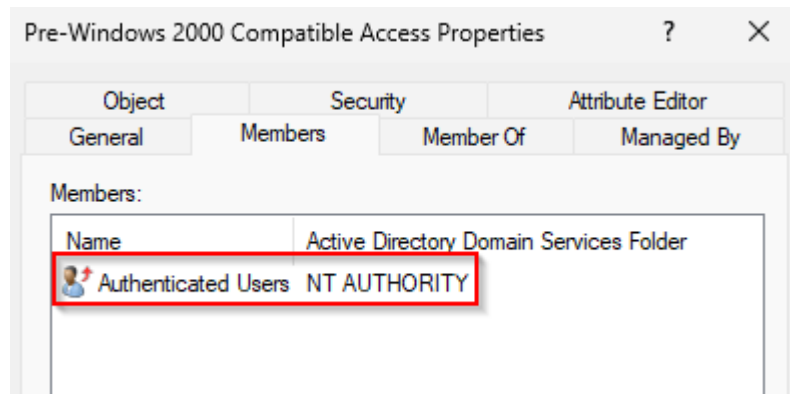
In the era of Windows NT4 you had the ability to gain access to certain objects like a computer or user, but you could not differentiate between attributes of that object, that's something Active Directory introduced. But you probably guessed it, there was a time of migration where NT4 based access to objects needed to remain in place for compatibility reasons, hence the availability of the "Pre-Windows 2000 Compatible Access" group.

If you would open Active Directory and browse to the security tab, you could actually see that the group provides access to all descendant group and user objects, meaning that it has full access to all the attributes of the objects. These Access Control Entries are propagated throughout almost every object in the AD hierarchy.



From a security point of view this is a problem, why? Well remember that I told you that Active Directory introduced the principle of least privilege? If you can read all the attributes of every object in AD that could be a reconnaissance nightmare because a potential attacker can now just query the content of high privilege groups, see last logon times, query if an account actually requires a password or all kind of useful information. And

here's the catch, you don't even need a user account for that, because the "Pre-Windows 2000 Compatible Access" group contains the pseudo group "Authenticated Users" and a computer, when authenticated is also part of this group. So all I need is a computer account to do the inventory. Hence the recommendation to remove the "Authenticated users" from the "Pre-Windows 2000 Compatible Access" group.



So what's the issue with PowerBI?

To be able to query data in a on-prem SQL database, Microsoft introduced the [PowerBI gateway](#). It's a piece of software that you install on a infrastructure server, connect it to the Cloud and your done. Once you have published a report from PowerBI desktop to the Cloud, assigned users will be able to open these reports online. They can query the on-prem data by using an authentication flow through the gateway.

So far so good, but what I experience at a specific customer is that this functionality would simply stop and authentication would break resulting in users being unable to use the online reports. Also a SQL Analysis Server trace showed errors indicating that the credentials could not be verified or were incorrect.

That got me thinking, why is that actually happening? So it seems that by default the PowerBI gateway actually uses the functionality provided by the "Pre-Windows 2000 Compatible Access" group so it could read **all** the attributes of a user (Why Microsoft?) and not just the attributes it needs to authenticate, sigh....

But I still needed to fix the PingCastle finding and remove the "Authenticated Users". So who does the actual check and authentication to AD and find out if the user executing the query is allowed to do so? It depends if you have a default configuration or if you're utilizing a Group Managed Service Account? As it turned out, the solution was relatively simple, but took a while to figure out. Use this guidance if you run into the same error:

- **Default Setup:** Add the Computer object of the Server where the analysis services is running on and place it in the “Pre-Windows 2000 Compatible Access” group.
- **When using a gMSA:** Add the gMSA object in the “Pre-Windows 2000 Compatible Access” group.

If the above is successful you could always consider using delegation to set the appropriate access rights on the organizational unit(s) where the PowerBI users are stored in AD. I haven't tried that just yet but I assume that it will need to be able to access the same attributes as the “Pre-Windows 2000 Compatible Access” group, but at least this group would be completely empty and your Active Directory is just a little bit safer.

Hopefully this information is useful to you and until next time and in between time, stay secure!